

10. Công Nghệ — Database & ORM

PostgreSQL 16 + Prisma ORM v7 — 37 models, schema-first approach.

- **Lý do chọn PostgreSQL:**
 - Tính toàn vẹn giao dịch cao (ACID) — quan trọng cho thanh toán và hóa đơn
 - Kiểu dữ liệu `Decimal` cho tiền tệ — tránh floating-point error
 - Hỗ trợ `@@unique` constraint — đảm bảo một serial chỉ thuộc một order
 - JSON fields cho linh hoạt mở rộng
- **Lý do chọn Prisma:**
 - Type-safe từ DB đến code — phát hiện lỗi schema lúc compile
 - Migration tự động — `prisma migrate dev` cho dev, `prisma migrate deploy` cho prod
 - Relation queries — `include` và `select` mạnh mẽ, giảm boilerplate
- **Quản lý tiền tệ:** Tất cả giá dùng `Decimal(12,2)`, không float.

11. Công Nghệ — Real-time Engine (Soketi)

Soketi — WebSocket server tự dựng, giao thức tương thích Pusher, chi phí thấp hơn Pusher SaaS.

- **Cấu hình tự dựng:**
 - Container chạy riêng trong Docker network
 - Backend trigger event qua Pusher PHP/Node SDK
 - Frontend nhận event qua `pusher-js`
 - Nginx reverse proxy: `wss://api.nextech.io.vn/app/*` → `soketi:6001`
- **Private Channel** `private-user.{userId}`:
 - Mỗi user chỉ nhận thông báo của chính mình
 - Xác thực qua endpoint `/notifications/auth` (JWT verify riêng)
 - Không ai có thể subscribe channel của người khác
- **Ưu điểm:** Độ trễ <10ms, không giới hạn concurrent connections, không tốn phí SaaS.

12. Công Nghệ — DevOps & Container

- **Docker Compose**: 5 containers trong 1 network
 - `frontend_app`: Nginx serving React build (port 3000)
 - `admin_app`: Nginx serving React build (port 3001)
 - `backend_app`: Express.js (port 5000)
 - `soketi_app`: Soketi WebSocket (port 6001)
 - `postgres_db`: PostgreSQL 16 (port 5432)
- **Nginx Reverse Proxy**: 1 entry point duy nhất (port 443)
 - Route theo subdomain: `nextech.io.vn`, `admin.nextech.io.vn`, `api.nextech.io.vn`
 - Let's Encrypt SSL tự động
- **Multi-stage builds**: Dockerfile tối ưu kích thước image, chỉ copy `node_modules` production

13. Thiết Kế CSDL — Users & Authentication

Models chính

Model	Mục đích
User	Khách hàng: email, password (hash), OAuth provider, profile
Admin	Quản trị viên: riêng biệt với User, không public register
OAuthAccount	Liên kết tài khoản Google/Facebook (provider + providerId)
RefreshToken	Lưu JWT refresh token, có thời gian hết hạn, liên kết User/Admin
RevokedToken	Blacklist token đã thu hồi — chống replay attack
PasswordResetToken	Token đặt lại mật khẩu, có expiry

Đặc điểm bảo mật

- Admin và User là 2 bảng riêng — không lộ admin endpoint cho user thường
- RefreshToken có `expiresAt` — tự động dọn dẹp job định kỳ
- RevokedToken ghi lại thời gian thu hồi — không thể dùng token cũ

14. Thiết Kế CSDL — Products & Catalog

Ma trận cấu hình sản phẩm (Product Variant Matrix)

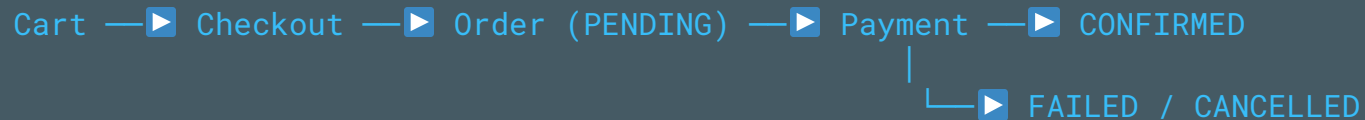
```
Product (iPhone 16 Pro)
├── ProductAttribute (Màu sắc: Xám, Vàng)
│   └── ProductAttributeValue (Gray, Gold)
├── ProductAttribute (Dung lượng: 128GB, 256GB)
│   └── ProductAttributeValue (128, 256)
└── ProductVariant (Kết hợp: Gray/128GB, Gray/256GB, Gold/128GB...)
    └── ProductVariantValue (Liên kết attribute → variant)
```

Models chính

Model	Chức năng
Product	Thông tin chung: tên, mô tả, giá gốc, brand, category
ProductImage	Gallery ảnh, ảnh đại diện, sort order
Brand	Thương hiệu (Apple, Samsung, Dell...)
Category, Tag	Phân loại và gắn thẻ sản phẩm, bài viết

15. Thiết Kế CSDL — Orders & Cart

Luồng hoạt động

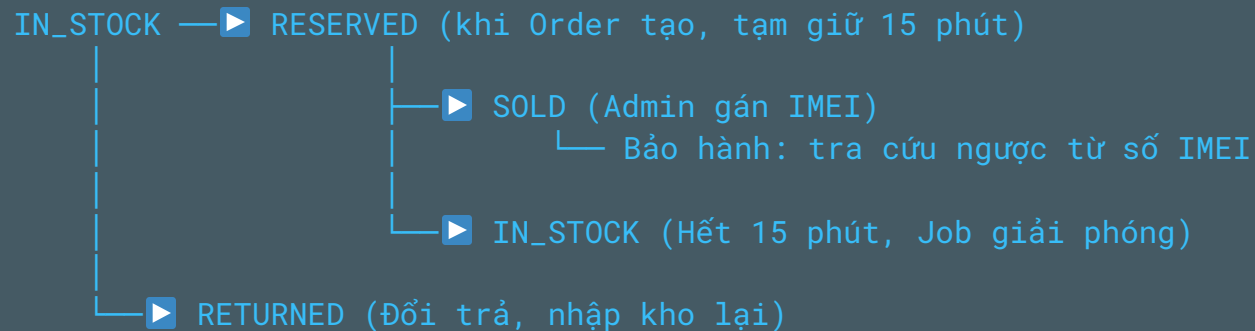


Models chính

Model	Chức năng
Cart	Giỏ hàng theo user, có expiry
CartItem	Sản phẩm trong giỏ, số lượng, variant
Order	Đơn hàng: status (PENDING → PROCESSING → CONFIRMED → SHIPPING → DELIVERED → CANCELLED), tổng tiền, shipping address
OrderItem	Chi tiết sản phẩm trong đơn (snapshot giá tại thời điểm mua)
Coupon	Mã giảm giá: percentage/flat, min order, expiry, usage limit
CouponUsage	Ghi lại ai đã dùng coupon — chống dùng lại
Review	Đánh giá sản phẩm sau khi nhận hàng

16. Thiết Kế CSDL — Serial IMEI & Kho Hàng

Vòng đời SerialUnit



Models chính

Model	Chức năng
Supplier	Nhà cung cấp: tên, liên hệ, địa chỉ
StockImport	Phiếu nhập kho: thời gian, tổng số lượng, supplier
SerialUnit	IMEI/Serial duy nhất: status, liên kết StockImport và OrderItem

Ràng buộc

- `@@unique([serialNumber, orderItemId])` — một serial chỉ gán một order item
- Tra cứu bảo hành: `IMEI → SerialUnit → OrderItem → Order → User`

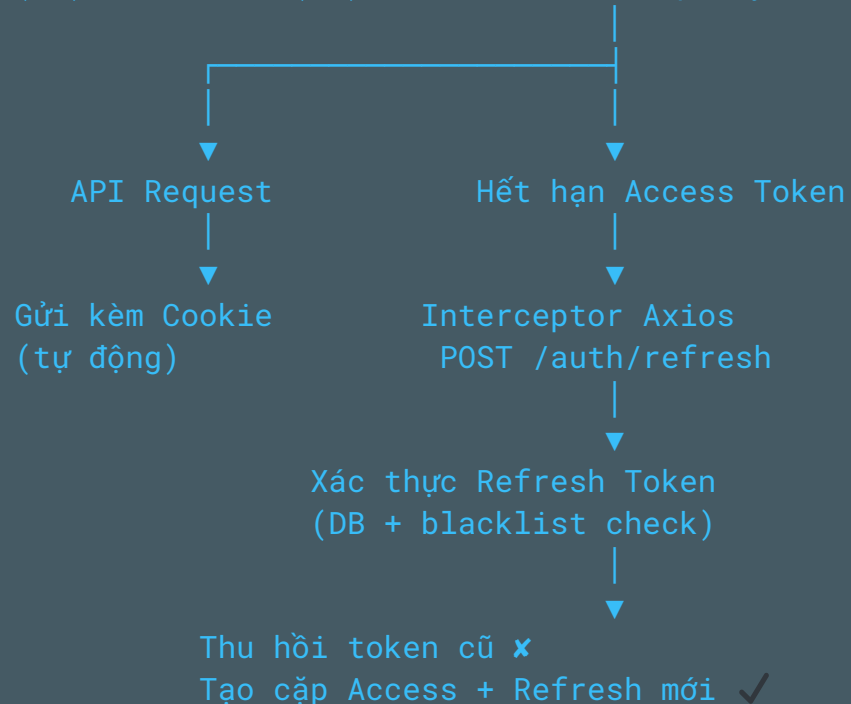
17. Thiết Kế CSDL — Tiện Ích & Vận Hành

Model	Chức năng
Notification	Thông báo real-time: user, message, type, read status
Post	Bài viết tin tức công nghệ (có scheduled publish)
Category, Tag	Phân loại bài viết (tái sử dụng với Product Category)
AIChatMessage	Lịch sử hội thoại chatbot AI (role: user/assistant, message)
ShopSettings	Cấu hình toàn cục: lowStockThreshold, orderAlertThreshold, VAT config
FailedEmail	Hàng đợi email lỗi: tự động retry qua cron job

18. Bảo Mật — Xác Thực JWT HttpOnly

Cơ chế Access/Refresh Token Rotation

Đăng nhập —▶ Tạo cặp Access (1h) + Refresh (7d) —▶ Lưu vào HttpOnly Cookie



- **Chống XSS:** Token không lưu trong `localStorage`, không thể bị đánh cắp qua JS injection
- **Chống CSRF:** Cookie `SameSite: Lax` + ký request signature qua `COOKIE_SECRET`

19. Bảo Mật — Pusher Private Channel Authentication

Vấn đề

- User và Admin dùng chung backend
- User có thể đã login admin trước đó (cookie `admin_access_token` tồn tại)
- Notification API user bị sai vì middleware ưu tiên admin token

Giải pháp

Endpoint POST /notifications/auth (BYPASS middleware protectUserOrAdmin)



1. Đọc cookie: thử `access_token` TRƯỚC → nếu có → verify → user channel
2. Nếu không có `access_token` → fallback `admin_access_token` → admin channel
3. Nếu cả hai đều không hợp lệ → 401 Unauthorized

- Middleware `protectUserOrAdmin` ưu tiên `access_token` (user) hơn `admin_access_token` (admin)
- Pusher auth endpoint hoàn toàn tách biệt, xác thực thủ công không qua middleware